



Coverity® Security Report

Ford
v. 1.4

Enterprise	Aditya Infotech Ltd
R&D	CP PLUS
Assurance Level	AL1 (90)
Severity Mapping	Carrier grade
Prepared For	Ford
Prepared By	Narsingh
Prepared On	Sep 27, 2024 3:25 PM

Coverity® Security Report

Executive Summary

This report details the application security assessment activities that were carried out, providing a summary of findings, compliance against published policy requirements, and remediation actions required. Also provided is a detailed breakdown and cross reference between technical findings and Coverity analysis results.

The intended audience for this report is an application security assurance team and their clients or end users. To review detailed code-level findings, it is recommended that developers click [this link to the Coverity Connect platform](http://172.16.0.32:8081/reports#p10022) (http://172.16.0.32:8081/reports#p10022) in order to see source code annotated with remediation recommendations.

Lines of Code Inspected: 201327

Scorecard

The issues were evaluated according to each element of the report's policy. The results are shown in the table below. An overall status of "pass" is assigned if all the policy elements passed.

Policy Element	Target	Value	Passed
Security Score	90	100	Yes
OWASP Top 10 Count	0	0	Yes
CWE/SANS Top 25 Count	0	0	Yes
Analysis Date	2024-8-28	2024-9-27	Yes
Overall Status			Yes

Additional Quality Measures

This table reports the numbers of issues of various categories that were not included in the Security Score calculation. Although they were excluded from the report, they may nonetheless indicate the presence of significant quality or security issues. Issues which do not have CWE number or Technical impact are counted as Non-Security issues.

Category	Count
Issues Marked "False Positive" or "Intentional"	1
Non-Security Issues	0
Issues Scored as "Informational"	0

Action Items

The code base was evaluated based on the policy in force. The policy has the following elements:

- The Security Score must meet or exceed the target set by the Assurance Level. See the [Security Details](#) section for more information.
- There must be no OWASP Top 10 issues among those found in the project. See the [OWASP Top 10](#) section for details.
- There must be no CWE/SANS Top 25 issues among those found in the project. See the [CWE/SANS Top 25](#) section for details.
- All snapshots must have been analyzed within 30 days. See the [Analysis Details](#) section for more information.

Coverity recommends the following actions in order to resolve critical outstanding issues, achieve compliance with policy, and improve the overall security of the software.

Security Score Remediation

No further issues need to be resolved to reach the target security score.

OWASP Top 10 Remediation

The project has no issues in the OWASP Top 10.

CWE/SANS Top 25 Remediation

The project has no issues in the CWE/SANS Top 25.

Recent Source Code Analysis

Regular source code analysis is key to identifying security issues in a timely manner and to ensuring that these issues are effectively eliminated, in-line with development activities.

The current results are sufficiently recent (less than 30 days old).

Long Term and Residual Risk Management

Review and consider broader improvement to the overall security posture of the target application.

Review outstanding lesser-rated issues to ensure minimal residual risk.

Review issues marked false positive to be sure that a coding change will not eliminate them.

Review any security issues marked Informational to see if some are in fact credible threats.

Review and correct non-security issues found by Coverity Analysis, in order to increase the overall quality of the code.

Security Details

The severity mapping shows how technical impacts (possible security flaws) are paired with severities. This severity mapping table also shows the number of issues for each technical impact.

Severity Mapping Name: Carrier grade
Severity Mapping Description: Very stringent

Technical Impact	Severity	Number of Issues
Execute unauthorized code	Very high	0
Gain privileges	Very high	0
Bypass protection mechanism	High	0
Denial of service, unreliable execution	High	0
Modify data	High	0
Denial of service, Resource consumption	Medium	0
Hide activities	Medium	0
Read data	Medium	0
Total		0

Coverity® Security Report

4

Analysis Details

A Coverity project is a collection of one or more streams containing separately-analyzed snapshots. The latest snapshot in each stream is used when reporting results for a project. This section gives details about the streams and the analysis performed for each snapshot.

Stream Name	Snapshot ID	Analysis Date	Analysis Version	Target
Ford_1	10265	2024-9-27 9:43:0 PM	2023.12.0	

The 2017 OWASP Top 10 List

The [Open Web Application Security Project](#) (OWASP) is an open community dedicated to enabling organizations to conceive, develop, acquire, operate, and maintain applications that can be trusted. The OWASP maintains the [OWASP Top 10 List for 2017](#), a prioritized list of security weaknesses. OWASP says, "We can no longer afford to tolerate relatively simple security problems like those presented in this OWASP Top 10."

Each entry in the OWASP Top 10 refers to a set of CWE entries. Those entries may be individual weaknesses or families of weaknesses. See [the next section](#) for further discussion.

The table below shows the number of issues found in each category of the OWASP Top 10 for 2017.

2017 OWASP Top 10 Categories	CWE Number	Count
1. Injection	1027	0
2. Broken Authentication	1028	0
3. Sensitive Data Exposure	1029	0
4. XML External Entities (XXE)	1030	0
5. Broken Access Control	1031	0
6. Security Misconfiguration	1032	0
7. Cross-Site Scripting (XSS)	1033	0
8. Insecure Deserialization	1034	0
9. Using Components with Known Vulnerabilities *	1035	0
10. Insufficient Logging & Monitoring	1036	0
Total		0

* Category 9 of the OWASP Top 10 for 2017, "Using Components with Known Vulnerabilities," is not detected by Coverity Static Analysis, but is detected by BlackDuck and Protecode ES, which are other Synopsys products.

Coverity® Security Report

5

The 2019 CWE/SANS Top 25 List

The Common Weakness Enumeration is a community-developed dictionary of software weakness types. The [2019 CWE/SANS Top 25 Most Dangerous Software Errors](#) (or, "Top 25") is a list of weaknesses, taken from the CWE, that are thought to be the most widespread and critical errors that can lead to serious vulnerabilities in software.

Each category in the Top 25 List mentions one primary CWE identifier (CWE ID). Such a CWE ID can refer to an individual weakness or to a family of related weaknesses, since a given CWE ID may have children CWE IDs, which in turn may have children CWE IDs of their own. A Coverity issue corresponds to the most relevant CWE ID. A CWE/SANS Top 25 Category will consist of all of the Coverity issues that correspond to either the mentioned CWE ID or to one of its associated descendants.

The table below lists all the entries of the Top 25 and shows how many Coverity issues in the current project were found to be members of the Top 25.

2019 CWE/SANS Top 25 Categories	CWE Number	Count
1. Improper Restriction of Operations within the Bounds of a Memory Buffer	CWE-119	0
2. Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	CWE-79	0
3. Improper Input Validation	CWE-20	0
4. Information Exposure	CWE-200	0
5. Out-of-bounds Read	CWE-125	0
6. Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	CWE-89	0
7. Use After Free	CWE-416	0
8. Integer Overflow or Wraparound	CWE-190	0
9. Cross-Site Request Forgery (CSRF)	CWE-352	0
10. Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22	0
11. Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	CWE-78	0
12. Out-of-bounds Write	CWE-787	0
13. Improper Authentication	CWE-287	0
14. NULL Pointer Dereference	CWE-476	0
15. Incorrect Permission Assignment for Critical Resource	CWE-732	0
16. Unrestricted Upload of File with Dangerous Type	CWE-434	0
17. Improper Restriction of XML External Entity Reference ('XXE')	CWE-611	0
18. Improper Control of Generation of Code ('Code Injection')	CWE-94	0
19. Use of Hard-coded Credentials	CWE-798	0
20. Uncontrolled Resource Consumption ('Resource Exhaustion')	CWE-400	0
21. Missing Release of Resource after Effective Lifetime	CWE-772	0
22. Untrusted Search Path	CWE-426	0
23. Deserialization of Untrusted Data	CWE-502	0
24. Improper Privilege Management	CWE-269	0
25. Improper Certificate Validation	CWE-295	0
Total		0

Detailed Issues Ranked By Severity

No security issues were found in the project.

Methodology

Introduction

This report is a distillation of the output of the Coverity Code Advisor used on a particular code source base. Coverity Code Advisor is a static analysis tool that is capable of finding quality defects, security vulnerabilities, and test violations through the process of scanning the output of a specially-compiled code base. The information in this report is specific to security vulnerabilities detected by Coverity Code Advisor and their categorization in the OWASP and CWE/SANS ranking systems.

About Static Analysis

Static analysis is the analysis of software code without executing the compiled program, for the purpose of finding logic errors or security vulnerabilities. Coverity's static analysis tools integrate with all major build systems and generate a high fidelity representation of source code to provide full code path coverage, ensuring that every line of code and execution path is analyzed. Code Advisor supports the market-leading compilers for C, C++, Java, C#, Objective C, and Javascript.

About CWE

CWE ([Common Weakness Enumeration](#)) is a software community project that is responsible for creating a catalog of software weaknesses and vulnerabilities and is sponsored by the office of Cybersecurity and Communications at the U.S. Department of Homeland Security. The Common Weakness Scoring System (CWSS) provides a method by which to identify and compare weaknesses.

CWE is used by vulnerability-listing efforts such as [CWE/SANS Top 25](#) and [OWASP Top 10](#), among others, to create generalized lists of ranked vulnerabilities. Some, but not all, of the issues reported by Coverity are mapped to CWE-listed vulnerabilities. The [Common Weakness Risk Assessment Framework](#) (CWRAF) is a methodology for prioritizing software weaknesses in the context of the software's use. A CWRAF "severity mapping" prioritizes issues according to their CWE technical impact values. There are 8 technical impacts:

1. modify data,
2. read data,
3. create a denial-of-service that results in unreliable execution,
4. create a denial-of-service that results in resource consumption,
5. execute unauthorized code or commands,
6. gain privileges or assume identity,
7. bypass protection mechanism,
8. hide activities

CWRAF and CWSS allow users to rank classes of weaknesses independently of any particular software package, in order to prioritize them relative to each other.

Setting Priorities with Severity Mappings

A severity mapping is a mapping that determines a severity level, or score, for a given technical impact associated with a software issue. This score can in turn be used to derive the priority assigned to the remediation of the issue. Coverity provides built-in severity mappings to help customers to set these priorities for particular types of applications, and the ability to create custom severity mappings.

The part of the severity mapping that's relevant for this work is the Technical Impact Scorecard. It maps a technical impact to a severity value between Informational (the lowest) and Very High (the highest). This value is known variously as the technical impact's "score" or its "severity". This document uses "severity".

Scoring Methodology

An issue from Coverity's code analysis will contribute to the security score when it has a CWE ID where the CWE ID maps to at least one of the eight technical impact values, at least one the mapped technical impact values has a severity level greater than Informational, and the issue has not been marked as "False Positive" or "Intentional". A severity mapping determines the mapping of technical impact values to severity levels and it is an issue's assigned severity level that is used for the security score calculation. For an issue where its CWE ID maps to more than one of the eight technical impact values, a single technical impact value will be assigned to the issue, where the highest relevant severity level will determine which technical impact value gets assigned, with ties for the highest severity level being broken arbitrarily.

The severity levels from the [Security Details](#) section are used to determine the security score, with the possible severity levels being Very High, High, Medium, Low, and Very Low. The highest severity level that has at least one issue associated with it will greatly influence the security score. Additional issues with the highest severity level will have a greater impact on reducing the security score than will additional issues with a relatively lower severity level. As such, it's important to address issues with the highest severity level.

While the full range of a possible security score is from 0 to 100, with 100 being the best value possible, only a project with a highest severity level of Very Low that contains 6 or less Very Low severity level issues can receive a score of 100. A project would need to contain more than 30000 Very High severity level issues to receive a score lower than 30. Meanwhile, a project with a highest severity level of Very Low would need to contain more than 30000 Very Low severity level issues to receive a score lower than 70.

To give some further context, consider the standard Target Assurance Levels plus their corresponding Target Security Score values of AL1 (90), AL2 (80), AL3 (70), and AL4 (60) relative to the highest severity level that has at least one issue associated with it.

- If Very High severity level issues exist, it will be nearly impossible to achieve AL3 (70), and it will be quite a challenge to achieve AL4 (60).
- If all of the Very High severity level issues have been addressed, but at least one High severity level issue exists, it will be nearly impossible to achieve AL2 (80), and it will be a reasonable challenge to achieve AL3 (70), with AL4 (60) being within easier reach.
- If all of the Very High and High severity level issues have been addressed, but at least one Medium severity level issue exists, it will be nearly impossible to achieve AL1 (90) and quite challenging to achieve AL2 (80), while AL3 (70) is more likely to be within reach, and AL4 (60) should be a relatively easy target to reach.

The OWASP Top 10 List

The OWASP (Open Web Application Security Project) Foundation is an international organization whose mission is to advance the cause of secure software. As part of its activities, OWASP publishes a report of the most critical web application security flaws in rank order based on the input of a worldwide group of security experts. The most recent version of this list and accompanying report is the [OWASP Top 10 List for 2017](#). The OWASP Top 10 List is referenced by many standards including MITRE, PCI DSS, DISA, and the FTC.

The CWE/SANS Top 25 List

The SANS Institute is a cooperative research and education organization made up security experts from around the world. SANS is a major source of information on computer security and makes available an extensive collection of research documentation. It also operates the Internet's early security vulnerability warning system, the Internet Storm Center. The 2019 CWE/SANS Top 25 Most Dangerous Software Errors is a list of the most common and critical errors that can lead to software vulnerabilities, as published by this organization.

About Coverity

Coverity is a leading provider of quality and security testing solutions. The company, founded in the Computer Science Laboratory at Stanford University, provides an array of tools that assist developers in addressing critical quality and security issues early in the development cycle, thus saving development organizations from remediating issues late in the development cycle or after release when they are much more costly. Many major software development organizations, including 8 of the top 10 global brands and 9 of the top 10 software companies, deploy Coverity analysis tools. Coverity also maintains a free, cloud based analysis platform, called Scan, for the Open Source Community.